



HARMONISED EUROPEAN STANDARD

Draft ETSI EN 304 625 V0.0.5 (2025-09-19)

CYBER; CRA; Essential cybersecurity requirements for physical and virtual network interfaces

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit <https://labs.etsi.org/rep/stan4cra/en-304-625> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

Reference :
DEN/CYBER-EUS-0017

Keywords

Cybersecurity, CRA, Interfaces

ETSI

650 Route des Lucioles

F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B

Association à but non lucratif enregistrée à la

Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our [Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or

other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided “AS IS” with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without

83 limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out
84 of or related to the use of or inability to use the software.

85
86

87 ***Copyright Notification***

88 No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying
89 and microfilm except as authorized by written permission of ETSI. The content of the PDF version shall not be
90 modified without the written authorization of ETSI. The copyright and the foregoing restriction extend to reproduction
91 in all media.

92 © ETSI 2025.

93 All rights reserved.

94

Contents

95	
96	HARMONISED EUROPEAN STANDARD
97	Intellectual Property Rights
98	Essential patents
99	Trademarks
100	Foreword
101	Modal verbs terminology
102	Executive summary
103	Introduction
104	1 Scope
105	1.1 General
106	1.2 Products in scope
107	1.3 Products not in scope
108	2 References
109	2.1 Normative references
110	2.2 Informative references
111	3 Definition of terms, symbols and abbreviations
112	3.1 Terms
113	3.2 Abbreviations
114	4 Product context
115	4.1 General
116	4.2 Out of scope use/environments
117	4.3 Product overview and architecture
118	4.3.1 Product overview
119	4.3.2 Types of network interface
120	4.3.3 Device drivers for network interfaces
121	4.4 Use cases
122	4.4.1 Wired network interface use cases
123	4.4.2 Wireless network interface use cases
124	4.4.3 Virtual network interface use cases
125	4.5 Risk factors
126	4.5.1 List of risk factors
127	4.5.1 Mapping of use cases to risk factors and security profiles
128	4.5.2.1 Wired network interface use cases
129	4.5.2.2 Wireless network interface use cases
130	4.5.2.3 Virtual network interface use cases
131	4.6 Security profiles
132	4.6.1 General
133	4.6.2 Mapping of security profile to risk factors
134	4.6.2.1 Wired network interface security profiles
135	4.6.2.2 Wireless network interface security profiles
136	4.6.2.3 Virtual network interface security profiles
137	4.7 Essential functions
138	4.7.1 Physical interface essential functions
139	4.7.2 Device driver essential functions
140	4.7.3 Virtual interface essential functions
141	4.8 Operational Environment
142	4.9 Users
143	4.10 Distribution of security functions
144	4.10.1 General
145	4.10.2 Security functions provided outside the product
146	4.10.3 Security functions provided to other components
147	5 Requirements specifications
148	5.1 Notes on the structure of requirements
149	5.2 Technical security requirements specifications
150	Threat: Out-of-bounds memory access caused by unvalidated input in incoming packets
151	Threat: Attacker causes network interface to stop functioning
152	Annex A (informative): Mapping between the present document and CRA requirements
153	Annex B (informative): Relationship between the present document and any related ETSI standards (if any)
154	Annex C (informative): Risk identification and assessment methodology

155	<u>C.1 Assets</u>
156	<u>C.1.1 Data</u>
157	<u>C.1.1.1 Physical network interfaces</u>
158	<u>C.1.1.2 Virtual network interfaces or device drivers</u>
159	<u>C.1.2 Product functions</u>
160	<u>C.1.2.1 General</u>
161	<u>C.1.2.2 Physical interface essential functions</u>
162	<u>C.1.2.2 Device driver essential functions</u>
163	<u>C.1.2.3 Virtual interface essential functions</u>
164	<u>C.2 Threats</u>
165	<u>C.2.1 Physical interfaces</u>
166	<u>C.2.2 Device drivers</u>
167	<u>C.2.3 Virtual interfaces</u>
168	<u>C.3 Assumptions</u>
169	<u>C.4 Risk assessments of threats</u>
170	<u>Annex D (informative): Risk evaluation guidance</u>
171	<u>D.1 Mapping of risks to requirements</u>
172	<u>D.2 Risks not treated by the requirements</u>
173	<u>D.3 Risk acceptance criteria</u>
174	<u>D.4 Residual risks</u>
175	<u>Annex L (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847</u>
176	<u>Annex <L+3> (informative): Bibliography</u>
177	<u>Annex <L+4> (informative): Change history</u>
178	<u>History</u>

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

DRAFT FOREWORD - DO NOT CONSIDER THE CONTENT

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Transposition table

The Harmonised Standard shall have appropriate transposition periods specified. A Harmonised Standard confers presumption of conformity when it has been published in the Official Journal of the European Union (OJEU) and transposed by a member state.

The Technical Body may propose different dates to the default ones (3, 6, 18). Technical Bodies who wish to propose different dates are advised to indicate this clearly in the approved committee draft.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard	
or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

The Technical Body should advise the ETSI Secretariat if the above default national transposition dates are inappropriate for the particular standard.

223

Modal verbs terminology

224

In the present document “**shall**”, “**shall not**”, “**should**”, “**should not**”, “**may**”, “**need not**”, “**will**”, “**will not**”, “**can**”

225

and “**cannot**” are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression

226

of provisions).

227

“**must**” and “**must not**” are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

229

Introduction

230

231

232

233

The present document is a European harmonised standard that defines cybersecurity requirements for products whose core function is as an virtual or physical network interface. Demonstrating compliance with this standard is not necessary, but doing so provides a presumption of conformity with Regulation (EU) 2024/2847, the Cyber Resilience Act [i.1].

234

235

236

The present document does not apply to products that contain network interfaces or are part of a network interface if the core purpose of the product is not that of a network interface. However, it may be useful as one part of the process of demonstrating compliance for a product containing or interacting with network interfaces.

1 Scope

1.1 General

The present document describes how to demonstrate compliance with requirements in the EU Regulation 2024/2847 under the conditions identified in Annex <L> of physical and virtual network interfaces within the context described in section 4, Product Context.

1.2 Products in scope

Products in scope include products whose core purpose is to serve as a virtual or physical network interface intended to enable the connection of a computing device to a network. A network interface provides connectivity via a device driver API operating at the data link layer.

Physical network interfaces are products with digital elements that directly connect a device to a network via an application programming interface (API) provided by device drivers, typically operating at the data link layer, and that feature hardware adapters to transmission media with corresponding firmware, typically operating at the physical and data link layer.

Virtual network interfaces are products with digital elements that directly or indirectly connect a device to a network via an API that emulates that of device drivers of physical network interfaces, typically operating at the data link layer.

This category includes but is not limited to wired and wireless network interface cards, controllers and adapters, such as for Wi-Fi, Ethernet, IrDA, USB, Bluetooth, NearLink, Zigbee, or Infiniband. It also includes modems that are designed to connect directly to a system bus on the host and provide connection from the host to analog transmission media, as for example Power Line Communication devices.

FIXME: choose something consistent for: * system bus * communication bus * host bus * examples USB and PCI E

This category includes purely virtual standalone products, such as virtual network interface cards, container network interfaces, VPN interfaces, and loopback interfaces.

This category includes products whose core function is a network interface and provides the feature of remote management interface for the network interface or the host system.

FIXME what to do about network interfaces with multiple adapters that have a non-default switch mode?

For the purposes of this standard, network interfaces will be split up into the following groups, due to their distinct threat models:

- Wired network interfaces
- Wireless network interfaces
- Virtual network interfaces

1.3 Products not in scope

Products not in scope include:

- Products whose primary purpose is not that of a network interface
- Switches, routers, and standalone modems
- Cables connected to network interfaces
- Software or hardware add-ons, changes, or upgrades not shipped by the manufacturer that substantially modify the product

This standard does not cover products in use in contexts other than those identified in Annex <L>.

2 References

2.1 Normative references

In Harmonised Standards these references shall be specific (identified by date of publication and/or edition number or version number) **publicly available and in English, except in exceptional circumstances making sure that impacts have been evaluated and explanations have been given on how any negative implications should be avoided**. See clauses 2.10.1 and 8.4 of the [EDRs] and the communiqué on “[References in ETSI Deliverables][References]”.

Guidance for selecting normative references in harmonised standards is given in clause 2.8.3 of the Vademecum on European standardisation. Please **systematically consult with your Technical Officer** for the latest guidance on normative references other than to ENs, ISO/IEC standards, notably to prevent the risk of non-acceptance.

Legal acts can never be used as normative references.

It is recommended that the number of references be limited to the minimum needed for the implementation/application of the ETSI Deliverables. References not directly concerned with the implementation/application/understanding of the ETSI Deliverable shall be listed in the Bibliography annex.

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox].

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

NONE AT PRESENT

- [1] <Standard Organization acronym> <document number> (<version number>): “<Title>”.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader’s understanding but are not required for conformance to the present document.

- [i.0] <Standard Organization acronym> <document number> (<version number>): “<Title>”.
- [i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)
- [i.2] EN 18031-1 (2024): “Common security requirements for radio equipment - Part 1: Internet connected radio equipment”.

- 318 • [i.3] EN 18031-2 (2024): "Common security requirements for radio equipment - Part 2: radio equipment
319 processing data, namely Internet connected radio equipment, childcare radio equipment, toys radio equipment
320 and wearable radio equipment".
- 321 • [i.4] EN 18031-3 (2024): "Common security requirements for radio equipment - Part 3: Internet connected
322 radio equipment processing virtual money or monetary value".

3 Definition of terms, symbols and abbreviations

3.1 Terms

This section provides terms and definitions based on CEN/CLC JTC13 WG09's work on terms and definitions, terms and definitions provided by ETSI EN 303 645/TS 103 701 and terms and definitions provided by CEN/CLC EN 18031 series.

For the purposes of the present document, the following terms apply:

Device driver: A device driver is a piece of software or firmware running on the host that enables communication on the network via the network interface

Network Device Driver Interface (NDDI) A standardized interface provided by the host operating system or software framework that abstracts the underlying network hardware or virtualized network devices.

Firmware: Software stored within a device's non-volatile memory, such as ROM or flash memory, and executed by different types of hardware which can include the physical network interface and the host

Host: Any equipment to which the network interface part provides additional functionality, mainly network connectivity, and to which connection is necessary for the network interface to operate

Network Interface (NI) : A physical device or software component that provides a host with a connection to a network

Physical transmission medium : The physical instantiation of a network, which can be wired or wireless

Physical transmission media adapter : A physical adapter on a network interface that transmits and receives data on the medium

Physical (network) interface: A network interface that represents an actual hardware network device.

System bus: A data transmission bus connecting one or more physical network interfaces to a host

Virtual Network Interface (VNI): A software-based network interface that simulates the functionality of a physical network adapter.

3.2 Abbreviations

For the purposes of the present document, the following abbreviations apply:

Abbreviation	Description
API	Application Programming Interface
ISP	Internet Service Provider
IT	Information Technology
NI	Network Interface
NDDI	Network Device Driver Interface
OS	Operating System
VNI	Virtual Network Interface

4 Product context

4.1 General

NOTE: This section's structure is built upon CEN/CLC JTC13 PT01's deliverable and might require restructuring based on its progress.

4.2 Out of scope use/environments

For the convenience of the developers of these standards, the following list is temporarily included and will be removed before publication:

The types of product with digital elements listed in the section do not fall within the scope of the the Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1], and are not covered by this standard:

1. Services, except for the remote data processing solutions for a covered product as defined in CRA recitals 11-12; article 3, 2 [i.1]
2. Products specifically designed or procured for national security and defence purpose as defined in CRA recitals 14 and 26; article 2, 7-8 [i.1]
3. Products developed for or used exclusively for internal use by public administration as defined in CRA recital 16; article 5, 2 [i.1]
4. Non-commercial free and open source software as defined in CRA recitals 17-21; article 13, 5 [i.1]
5. Medical Devices and Software as defined in CRA recital 25; article 2, 2 [a-b] [i.1]
6. Vehicles, including aviation and marine equipment as defined in CRA recital 27; article 2, 2.c "vehicles"; recital 27; article 2, 3 "aviation"; article 2, 4 "marine equipment" [i.1]
7. Spare and used parts as defined in CRA recital 29; article 2, 6 [i.1]
8. Refurbished, repaired, and upgraded products that have not been substantially modified as defined in recitals 39 - 42 [i.1]

The following types of products have reduced or varied requirements under Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1] and can only be partially covered by this standard:

1. High Risk AI as defined in CRA recital 51; article 12 [i.1]
2. Testing and unfinished versions as defined in recital 37; Article 4, 2-3 [i.1]
3. Products Placed on the Market Prior to December 11, 2027 as defined in CRA article 69 [i.1]

Out of scope use cases and environments include those explicitly carved out by the Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1], and are not covered by this standard.

4.3 Product overview and architecture

4.3.1 Product overview

A physical network interface consists of:

- A local bus interface to connect to the host via a communications bus
- A hardware transceiver to communicate on the network
- Hardware and firmware to process incoming signals and host commands

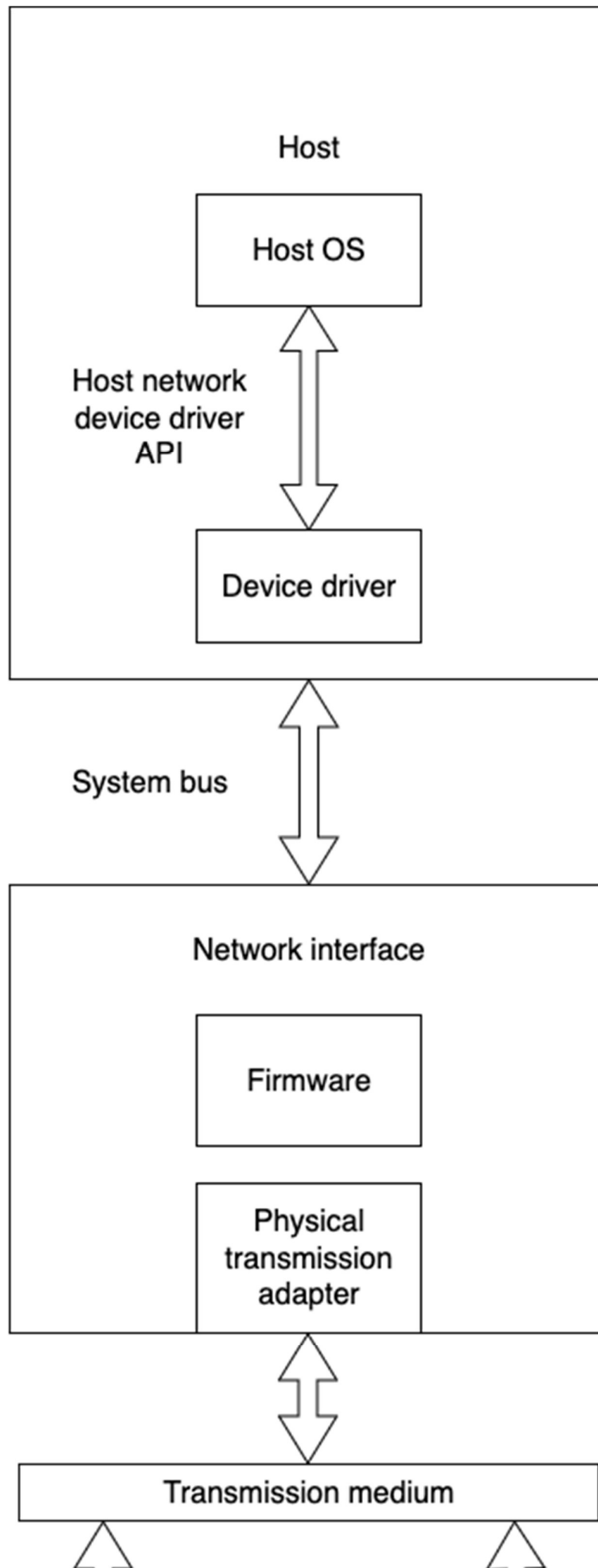
384 It also includes the following parts if they are sold with the interface:

- 385 • Device driver
- 386 • Removable/changeable antenna
- 387 • Daughter boards/add-on hardware modules

388 A virtual network interface consists of a device driver only.

389 4.3.2 Types of network interface

390 A physical network interface connects via the local communications bus to the host. The host transmits and receives
391 data to the network by means of the local bus interface provided by the network interface. A physical network interface
392 can typically directly read and write the host memory and raise interrupts. It sometimes has more advanced features that
393 allow it to power cycle the entire system, download files using simple protocols, and act as a simple boot loader.



~~Physical network device architecture~~

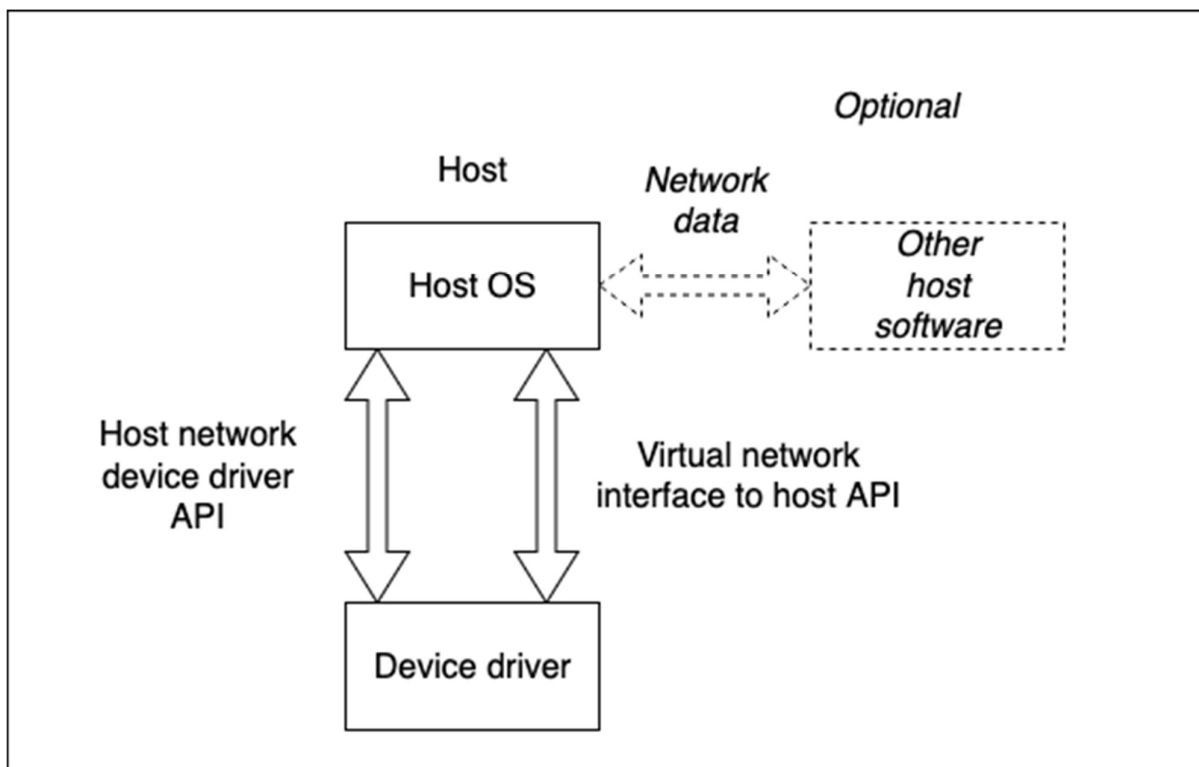
FIXME mermaid chart temporarily removed to generate Word doc

A wired network interface transmits data via a wired medium such as Ethernet cable, fiber optic cable, coaxial cable or power lines. A wireless network interface uses radiofrequency transmissions to transmit data over the air. A virtual network interface transmits data through software within the memory of a host system, sometimes across a software-defined network fabric.

Wireless network interfaces often have an independent real-time operating system on the network interface itself. Wireless medium access often requires real-time response to manage the radio frequency transmissions properly. The network interface must also prevent improper settings of radio frequency transmission parameters, which is often implemented by having the internal firmware set the parameters, rather than exposing them to the host. The complexity of this firmware may increase the risk of a wireless interface.

A virtual interface emulates the device driver interface of a network interface to a host's device driver API. Instead of a physical network interface, it may send and receive packets to a hypervisor, a container, another device driver, another part of the network stack, an application, or other software.

FIXME add hypervisor or other software to diagram



~~Virtual network device architecture~~

4.3.3 Device drivers for network interfaces

The device driver communicates with the host software or firmware by means of a network device driver API. This API abstracts the implementation details of the underlying network interface. Such network device driver API is typically defined by the host operating system or other software and is used by the host network stack to send or receive data through the network interface.

Physical interfaces require device drivers to make use of the physical hardware through the local communication bus. Virtual interfaces are effectively device drivers only, since they are made of software only without underlying hardware.

The device driver often needs elevated privileges to read and write memory. Device drivers for physical network interfaces often must have access also to the network interface control registers, directly or via host memory address space mapped to them; sometimes device drivers must as well enable or disable interrupts or other host hardware functions. This usually requires that the device driver has a high level of privilege on the host system.

4.4 Use cases

This list of use cases describes several system scenarios for network interfaces, intended as an informative resource to the manufacturer to simplify the choice of a set of security requirements. Each use case is mapped to a security level, which is a collection of risks and the security requirements necessary to mitigate them.

4.4.1 Wired network interface use cases

- UC-WD-1 Wired professional device in isolated internal infrastructure
 - E.g. Data center for internal job processing, smart meter in an isolated private network
 - Behind a firewall/gateway, no direct route to internet
 - Users are administrators and approved (predefined, fixed) applications
 - Network interface implements performance optimizations
 - Professional administration
- UC-WD-2 Wired professional device in internal infrastructure
 - E.g. switches behind edge firewall devices
 - Behind a firewall, routing filtered internet traffic
 - Users are administrators
 - Network interface implements performance optimizations
 - Professional administration
- UC-WD-3 Wired professional edge device or internet infrastructure
 - E.g. firewalls, VPN servers, switches in IXPs and ISPs, smart meter gateways and data concentrators in a smart metering system
 - Exposed to entire internet on the public network side
 - Users are administrators and approved applications
 - Network interface implements performance optimizations
 - Professional administration
- UC-WD-4 Wired professional worker device on internal network
 - E.g. stationary personal computer, registration terminal, cash register

- 450 ○ Behind a corporate firewall
- 451 ○ Users are company employees
- 452 ○ Network interface implements performance optimizations
- 453 ○ Professional administration
- 454 • UC-WD-5 Wired stationary home device
 - 455 ○ E.g. stationary personal computer, IoT hub, thermostat, TV
 - 456 ○ Behind home gateway firewall
 - 457 ○ Host access limited to people within the home
 - 458 ○ Simple, low-feature network interface implementation
 - 459 ○ Non-professional administration
- 460 • UC-WD-6 Wired stationary home gateway
 - 461 ○ E.g. ISP-managed access point
 - 462 ○ Exposed to the entire internet, with potentially some ISP filtering
 - 463 ○ Host access limited to trusted users/systems
 - 464 ○ Simple, low-feature network interface implementation
 - 465 ○ Mix of professional and non-professional administration
- 466 • UC-WD-7 Wired stationary public server
 - 467 ○ E.g. shared webhosting
 - 468 ○ Behind some firewall
 - 469 ○ Can be used by anyone who can open an account
 - 470 ○ Network interface implements performance optimizations
 - 471 ○ Professional administration
- 472 • UC-WD-8 Wired stationary device for public use
 - 473 ○ E.g. public library computer, vending machine
 - 474 ○ Behind some firewall, network accessible by physically nearby attackers
 - 475 ○ Can be used by anybody
 - 476 ○ Simple, low-feature network interface implementation
 - 477 ○ Professionally administered but likely under-resourced
- 478 • UC-WD-9 Wired mobile device
 - 479 ○ E.g. laptop
 - 480 ○ Exposed to entire internet, physically nearby attackers
 - 481 ○ Users limited to owner and a limited number of people they trust
 - 482 ○ Simple, low-feature network interface implementation
 - 483 ○ Non-professional administration

4.4.2 Wireless network interface use cases

- UC-WL-1 Wireless mobile enterprise worker device
 - E.g. company laptop, phone, tablet
 - Exposed to entire internet via any access point
 - Users are company employees
 - Interface implements radio control and encryption
 - Professional administration
 - UC-WL-2 Wireless stationary home IoT device
 - E.g. IoT lightbulb, smart oven, stationary personal computer
 - Behind home gateway firewall, network accessible by physically nearby attackers
 - Host access limited to people within the home
 - Interface implements radio control and encryption
 - Non-professional administration
- FIXME: update below and above
- UC-WL-2A Wireless stationary home computer
 - E.g. stationary personal computer
 - Behind home gateway firewall, network accessible by physically nearby attackers
 - Host access limited to people within the home
 - Interface implements radio control and encryption
 - Non-professional administration
 - UC-WL-3 Wireless stationary device for public use
 - E.g. public library computer, vending machine
 - Behind some firewall, network accessible by physically nearby attackers
 - Can be used by literally anybody
 - Interface implements radio control and encryption
 - Professional administration but likely under-resourced
 - UC-WL-4 Wireless mobile personal device
 - E.g. laptop, phone, tablet, watch
 - Exposed to entire internet, physically nearby attackers
 - Users limited to owner and a few people they trust
 - Interface implements radio control and encryption
 - Non-professional administration

4.4.3 Virtual network interface use cases

- UC-VI-1 Virtual interface for internal use on private device

- 518 ○ E.g. loopback, containers, tunnel to local application
- 519 ○ Packets only from other applications/users on host
- 520 ○ Users limited to owner and who they trust
- 521 ○ Very simple device driver
- 522 ○ Professional administration
- 523 • UC-VI-2 Virtual interface for external use on private device
 - 524 ○ Virtio on hypervisors, VPN interfaces, tunnel interfaces
 - 525 ○ Exposed to entire internet
 - 526 ○ Users limited to owner and who they trust
 - 527 ○ Highly complex packet filtering, processing, encryption, etc.
 - 528 ○ Non-professional administration
- 529 • UC-VI-3 Virtual interface for external use on enterprise device
 - 530 ○ Virtio on hypervisors, VPN interfaces, tunnel interfaces
 - 531 ○ Exposed to entire internet
 - 532 ○ Users are company employees
 - 533 ○ Highly complex packet filtering, processing, encryption, etc.
 - 534 ○ Professional administration
- 535 • UC-VI-4 Virtual interface for external use on public server
 - 536 ○ Virtio on hypervisors, VPN interfaces, tunnel interfaces
 - 537 ○ Exposed to entire internet
 - 538 ○ Users are untrusted
 - 539 ○ Highly complex packet filtering, processing, encryption, etc.
 - 540 ○ Professional administration

541 4.5 Risk factors

542 4.5.1 List of risk factors

543 The risk factors identified by the risk assessment in Annex C are grouped into risk categories and assigned unique
 544 identifiers below.

545 **[USR]** Number of agents with unprivileged access to the network interface on the host system

546 This measures how many agents on the host can access the network interface from the host using the normal
 547 unprivileged system interfaces such as TCP or UDP sockets. It assumes that raw sockets or access to the configuration
 548 functions of the network interface are only available to privileged users.

- 549 • **[USR-L-0]** Effectively no agents
- 550 • **[USR-L-1]** Only trusted agents with a formal approval system
- 551 • **[USR-L-2]** Trusted agents within the home
- 552 • **[USR-L-3]** Untrusted agents

553 FIXME: need to express risk coming from host system due to likelihood of being hacked that is different between a
 554 small single purpose IoT device and a full personal computer

555 **[ACC]** Degree of access to attached network by untrusted entities

556 This measures how easy it is for untrusted entities to send packets that the network interface will receive from outside
 557 the host, such as a user or program on another host attached to the same network.

558 • **[ACC-L-0]** Untrusted users have no or highly filtered access to attached network

559 • **[ACC-L-1]** Untrusted users have somewhat filtered access to attached network

560 • **[ACC-L-2]** Untrusted users have unfiltered access to attached network

561 **[COM]** Complexity of network interface implementation

562 • **[COM-L-0]** Minimal features to send/recv packets

563 • **[COM-L-1]** Some simple performance features

564 • **[COM-L-2]** Encryption features on device

565 • **[COM-L-3]** Entire RTOS managing radio, PXE boot, remote management, or similar

566 **[ADM]** Effectiveness of administration

567 • **[ADM-L-0]** Professional administration, fully resourced

568 • **[ADM-L-1]** Non-professional administration, professional but under-resourced, or mixed

569 4.5.1 Mapping of use cases to risk factors and security profiles

570 4.5.2.1 Wired network interface use cases

Use case	USR	ACC	COM	ADM	Sec Pro
UC-WD-1 Wired enterprise device in isolated internal infrastructure	L-0	L-0	L-1	L-0	SP-WD-1
UC-WD-2 Wired enterprise internal infrastructure device	L-0	L-1	L-2	L-0	SP-WD-1
UC-WD-3 Wired enterprise edge device or internet infrastructure	L-0	L-2	L-2	L-0	SP-WD-1
UC-WD-4 Wired enterprise worker device on internal network	L-1	L-1	L-2	L-0	SP-WD-1
UC-WD-5 Wired stationary home device	L-2	L-1	L-0	L-1	SP-WD-2

Use case	USR	ACC	COM	ADM	Sec Pro
UC-WD-6 Wired stationary home gateway	L-0	L-2	L-0	L-1	SP-WD-2
UC-WD-7 Wired stationary public server	L-3	L-2	L-1	L-0	SP-WD-2
UC-WD-8 Wired stationary device for public use	L-3	L-2	L-0	L-1	SP-WD-2
UC-WD-9 Wired mobile device	L-2	L-2	L-0	L-1	SP-WD-2

571 4.5.2.2 Wireless network interface use cases

Use case	USR	ACC	COM	ADM	Sec Pro
UC-WL-1 Wireless mobile enterprise worker device	L-1	L-2	L-3	L-0	SP-WL-1
UC-WL-2 Wireless stationary home device	L-2	L-1	L-3	L-1	SP-WL-1
UC-WL-3 Wireless stationary device for public use	L-3	L-2	L-3	L-1	SP-WL-2
UC-WL-4 Wireless mobile personal device	L-2	L-2	L-3	L-1	SP-WL-2

572 4.5.2.3 Virtual network interface use cases

Use case	USR	ACC	COM	ADM	Sec Pro
UC-VI-1 Virtual interface for internal use	L-2	L-0	L-0	L-1	SP-VI-1
UC-VI-2 Virtual interface for external use on private device	L-2	L-2	L-2	L-1	SP-VI-2
UC-VI-3 Virtual interface for external use on enterprise device	L-1	L-1	L-2	L-0	SP-VI-2
UC-VI-4 Virtual interface for	L-3	L-2	L-2	L-0	SP-VI-2

Use case	USR	ACC	COM	ADM	Sec Pro
external use on public server					

4.6 Security profiles

4.6.1 General

Security profiles are an informative resource to the manufacturer. Each security profile is associated with a collection of levels of risk factors. Security profiles will be mapped to specific mitigations for each security requirements necessary to treat the risk.

4.6.2 Mapping of security profile to risk factors

Security profiles are associated with sets of risk factor levels.

4.6.2.1 Wired network interface security profiles

Security profile	USR	ACC	COM	ADM
SP-WD-1	USR-L-1	ACC-L-2	COM-L-2	ADM-L-0
SP-WD-2	USR-L-3	ACC-L-2	COM-L-0	ADM-L-1

4.6.2.2 Wireless network interface security profiles

Security profile	USR	ACC	COM	ADM
SP-WL-1	USR-L-2	ACC-L-2	COM-L-3	ADM-L-1
SP-WL-2	USR-L-3	ACC-L-2	COM-L-3	ADM-L-1

4.6.2.3 Virtual network interface security profiles

Security profile	USR	ACC	COM	ADM
SP-VI-1	USR-L-2	ACC-L-0	COM-L-0	ADM-L-1
SP-VI-2	USR-L-3	ACC-L-2	COM-L-1	ADM-L-1

4.7 Essential functions

4.7.1 Physical interface essential functions

- Receive and transmit data between host and network at data link layer
- Execute host commands (power, config, tx/rx)
- Send commands/data to host hardware (wake on LAN)
- Keep and report network statistics
- Update firmware with image provided by host

Optional:

- Send commands/trigger actions on host (e.g. wake on network messages)

- 592 • Packet processing (receive/transmit) at layers higher than data link
- 593 • Packet encryption at data link layer
- 594 • Packet encryption at higher layer
- 595 • Manage firmware update autonomously (image received from the network)

596 4.7.2 Device driver essential functions

- 597 • Bridge between network device interface and host software
- 598 • Handle interrupts, set up tx/rx, copy statistics, etc.
- 599 • Configure the network interface
- 600 • Set up and execute firmware update/load with image provided by host software
- 601 • Monitor device interface and network interface health

602 Optional:

- 603 • Support optional features of the underlying device hardware or software

604 4.7.3 Virtual interface essential functions

- 605 • Bridge between host device driver interface and other software

606 Other functionality is generally implemented outside of the device driver.

607 4.8 Operational Environment

608 The technical requirements of the present document apply under the environmental profile for operation of the
 609 equipment, which shall be in accordance with its intended use. The equipment shall comply with all the technical
 610 requirements of the present document at all times when operating within the boundary limits of the operational
 611 environmental profile defined by its intended use.

612 The manufacturer shall document and communicate the expected environmental profile for the product to the consumer.

613 The network interface will operate in the context of a host system and operating system or other software. If the device
 614 driver is not included with the product, it will be provided by the operating system or other part of the system. See
 615 Section 4.10 for more details.

616 4.9 Users

617 While users of almost every product with digital elements are also using a network interface, the users for the purpose
 618 of this standard are restricted to those removing, installing, administering, or otherwise directly interacting with the
 619 network interface as an individual product.

- 620 • Personal computer user adding/removing/administering a network interface
- 621 • Corporate computer user adding/removing/administering a network interface
- 622 • Computer hobbyist experimenting with network interfaces
- 623 • Enterprise IT worker installing or administering a network interface
- 624 • Software developer writing drivers or debugging

4.10 Distribution of security functions

4.10.1 General

For each security requirement, a product may:

1. Provide all necessary security functions itself
2. Require security functions be provided by some other part of its context
3. Provide security functions for the use of other components

For example, most individual hardware components do not have a built-in method of securely updating any firmware in the product. Usually this requires a full-featured system running an operating system which can check for firmware updates, download and verify them, and carry out the process of updating the firmware.

4.10.2 Security functions provided outside the product

The following security functionalities are frequently handled by the operating system or other external component:

- Secure by default configuration
- Secure configuration changes
- Secure update of firmware and/or device driver
- Authentication of users
- Authorization of users
- Deletion and transfer of user data
- Provision of cryptographic keys to network interface

4.10.3 Security functions provided to other components

The network interface provides the following security functions to other parts of the system:

- Reporting of network-related statistics

Optional:

- Integrity protection via data link layer error detection and correction
- Confidential communication channel when providing encryption at the data link layer (WPA2, MACSEC)
- Availability protection via packet processing offload features

5 Requirements specifications

5.1 Notes on the structure of requirements

The most important quality of a technical requirement is that it should ideally be objectively testable on an instance of the product and the documentation that is required to be produced and saved by the manufacturer (and provided to the MSA on request).

The alternative option is “check-box” requirements, which only require that the vendor document that they did a thing (“Did you have every commit code-reviewed by a second person? [x] Yes [] No”).

We should prefer testable requirement to check-box requirements, but when a requirement isn’t testable, we can provide a decision tree where the vendor follows specific instructions to document why they have to use a check-box requirement (something that is documentation-only).

The goal is that when the MSA does a “sweep” or otherwise decides to verify a product’s conformance with the CRA, it has enough information that it can do its own independent testing without unnecessary barriers that could be solved by vendor documentation (e.g., does not have to reverse-engineer how to attach a serial console and read logs).

How exactly this will be done is yet to be determined, but here is our proposal:

- The vendor’s documentation must include information about each test it ran, including:
 - any physical equipment other than the product’s normal operating environment
 - any testing software they used, including versions
 - documentation for any testing software or hardware used
 - the parameters or arguments they used for the software or hardware
 - any setup information for the test (load this module, flip this switch, run this script, etc.)
- The standard can include requirements for the tools used in the test itself (features or sensitivity or maybe even source code available?)
- Any tests should demonstrate both the failure and success version of the test to rule out false positives or negatives Mitigations are how a technical requirement can be satisfied. Mitigations must be tailored to the use case and take into account the user’s sophistication and the operational environment.

5.2 Technical security requirements specifications

FIRST DRAFT

Threat: Out-of-bounds memory access caused by unvalidated input in incoming packets

Mitigations: Select from the following depending on use case/risk factor (TBD)

Fuzz packet input with memory use checker

- Test: run a packet fuzzer on instrumented firmware in simulator with memory access checking until it reaches NN% code coverage (NN based on overall risk)
- Result: simulator shows no out-of-bounds memory access
- Documentation: what simulator and fuzzer was used, with what configuration
- False negative prevention: create a firmware version that DOES allow an out-of-bounds write and show that it is logged by the simulator

Source code analysis

- 688 • Test: run a source code analyzer that statically checks for out-of-bounds memory access
- 689 • Result: analyzer results shows no out-of-bounds memory access
- 690 • Documentation: source code, what source code analyzer was used, what parameters, any explanations of false
- 691 positives or annotations in the source code that are instructions to the analyzer
- 692 • False negative prevention: create a firmware version that DOES allow an out-of-bounds write and show that
- 693 the analyzer catches it

694 Implement in a memory-safe language

- 695 • Test: examine source code and firmware to see if they are in a memory-safe language
- 696 • Result: source code is in a memory-safe language, binary appears to be built from the source, any part of the
- 697 source code that allows unsafe memory access has documentation explaining why it does not affect memory
- 698 safety
- 699 • Documentation: source code, how to copy firmware from device

700 Threat: Attacker causes network interface to stop functioning

701 Mitigations:

702 Watchdog resets interface after interface stops responding

- 703 • Test: use debug interface to halt firmware
- 704 • Result: after N seconds, the interface restarts
- 705 • Documentation: how to enable debug interface, how to halt firmware, how to get log of restart
- 706 • False positive prevention: prevent any rx/tx/configuration/etc. activity on the card for N+1 seconds and see that
- 707 it does not restart

Annex A (informative): Mapping between the present document and CRA requirements

Table mapping technical security requirements from Section 5 of the present document to essential cybersecurity requirements in Annex I of the CRA. The purpose of this is to help identify missing technical security requirements.

FIXME add requirements when they exist

CRA requirement	Technical security requirements(s)
No known exploitable vulnerabilities	
Secure design, development, production	
Secure by default configuration	
Secure updates	
Authentication and access control mechanisms	
Confidentiality protection	
Integrity protection for data and configuration	
Data minimization	
Availability protection	
Minimize impact on other devices or services	
Limit attack surface	
Exploit mitigation by limiting incident impact	
Logging and monitoring mechanisms	
Secure deletion and data transfer	

714 **Annex B (informative): Relationship between the present**
715 **document and any related ETSI standards (if any)**

716 List any related ETSI standards and how they interact with the present document.

Annex C (informative): Risk identification and assessment methodology

C.1 Assets

C.1.1 Data

What data is stored on the product?

C.1.1.1 Physical network interfaces

- Firmware
- Device configuration (transmit power/channel configuration/options)
- Statistics
- Security keys (firmware encryption/decryption, MAC level encryption/decryption)

C.1.1.2 Virtual network interfaces or device drivers

- Device driver code
- Interface configuration that is not stored by the host
- Statistics
- Security keys

C.1.2 Product functions

C.1.2.1 General

FIXME copy back to Essential Functions when done

Copied from Section 4.7 Essential Functions.

C.1.2.2 Physical interface essential functions

- Receive and transmit data between host and network at data link layer
- Execute host commands (power, config, tx/rx)
- Send commands/data to host hardware (wake on LAN)
- Keep and report network statistics
- Update firmware with image provided by host

Optional:

- Send commands/trigger actions on host (e.g. wake on network messages)
- Packet processing (receive/transmit) at layers higher than data link
- Packet encryption at data link layer
- Packet encryption at higher layer

- Manage firmware update autonomously (image received from the network)

FIXME add in system bus related risks

C.1.2.2 Device driver essential functions

- Bridge between network device interface and host software
- Handle interrupts, set up tx/rx, copy statistics, etc.
- Configure the network interface
- Set up and execute firmware update/load with image provided by host software
- Monitor device interface and network interface health

Optional:

- Support optional features of the underlying device hardware or software

C.1.2.3 Virtual interface essential functions

- Bridge between host device driver interface and other software

Other functionality is generally implemented outside of the device driver.

C.2 Threats

Based on the assets, what are the threats during:

- Use for intended purpose or reasonably foreseeable use
- When integrated into another product

Example threats can be found in the same documents suggested in the section on security requirements.

FIXME partial notes, need more threats, need to associate with risk factors

C.2.1 Physical interfaces

- Incoming packet can exploit a bug to:
 - Read/write firmware
 - Read/write configuration
 - Read/write statistics
 - Read/write security keys
 - Read/write packet contents
 - Stop packet processing
 - Slow down packet processing
 - Drop packets
 - Send interrupts to host
 - Reboot the host
 - Read/write host memory

- Unprivileged user

781 C.2.2 Device drivers

782 FIXME copy from OS

783 C.2.3 Virtual interfaces

784 FIXME copy from OS and add the very small amount of different stuff to mitigate the specific data that is different in a
785 virtual interface.

786 Unsorted notes

787 Physical interfaces:

- 788 • Incoming packets that trigger bad behaviour
 - 789 ○ Bug that processing incoming packets stops packet processing
 - 790 ▪ TR: watchdog timeout that resets card if packets aren't coming out right?
 - 791 ▪ TR: fuzz testing of network input packets (directed maybe, specify numbers and test?)
 - 792 ▪ TR: stress testing with just a lot of packets of different types?
 - 793 ▪ TR: general secure design stuff PT1 that we can only do if testable on product
- 794 • Bugs in chipset allowing unauthorized/malformed access to interface
- 795 • Malicious/corrupted firmware updates - do this securely
 - 796 ○ TR: the firmware update method must verify firmware in some way
 - 797 ○ note that update can be done OS or other stuff
 - 798 ○ IoT things updated over wifi
- 799 • Bluetooth is exposed to the world and very common
- 800 • development/debug commands accessible externally from host
 - 801 ○ TR: debug interfaces disabled by default
 - 802 ○ TR: debug interface is only used by authorized users via SoTA
- 803 • extended feature sets not generally used by default
 - 804 ○ TR: disabled by default
- 805 • automatically connecting to an open network where a closed/encrypted one was remembered
- 806 • buffer overflow (in network interface)
 - 807 ○ TR: bounds check on packet buffer descriptors
 - 808 ○ TR: bounds check on any kind of length field
 - 809 ○ TR: contains only data host wants sent
 - 810 ○ TR: compiler-based checks
- 811 • DoS by external packets
 - 812 ○ TR: do validity checks as soon as possible before doing lots of processing
- 813 • switching to less secure state without user realizing it

- 814 ○ TR: test that it doesn't do this
- 815 ○ TR: reset of firmware does not lose security configuration
- 816 • stack smashing (overwrite return address or value on stack)
- 817 ○ TR: general stack stuff
- 818 • encryption failures in on-interface implementations WPA2, MACSEC
- 819 ○ TR:
- 820 • bugs in various offload features
- 821 ○ segmentation offload - recommend specific tests?
- 822 • programmable FPGA
- 823 ○ as long as not doing something by default, this is sophisticated user
- 824 • remote management interface
- 825 ○ TR: disabled by default
- 826 ○ TR: no default auth by default
- 827 ○ TR: auth should be done
- 828 • remote boot
- 829 ○ TR: disabled by default
- 830 • remote firmware update
- 831 ○ TR: disabled by default
- 832 • TR: tests on source code provided to the MSA (not necessarily public)
- 833 • TR: DAST dynamic applications security testing
- 834 • TR: open source your code and use open source tools?
- 835 FIXME: reference or use IEC 62443 certification? industrial use case, mostly for B2B relationships, suppliers,
- 836 sophisticated, we are more consumer-related, probably can't base it on but we can find some overlap and inspire this
- 837 standard

838 Potential sources of threats:

839 A generic CVE for many NICs that copied data beyond the end of the packet in memory and sent it on the network.

840 <https://www.intel.com/content/www/us/en/security-center/advisory/intel-sa-01335.html>

841 <https://www.ibm.com/support/pages/security-bulletin-vulnerability-has-been-discovered-40-gbe-network-interface-modules-ibm-security-network-protection-xgs-7100-appliance-cve-2016-8106>

842

843 <https://app.openCVE.io/cve/CVE-2016-8106>

844 <https://cyber.gouv.fr/sites/default/files/IMG/pdf/csw-trustnetworkcard.pdf>

845 <https://nvd.nist.gov/vuln/detail/CVE-2018-6973>

846 <https://cert.europa.eu/static/security-advisories/CERT-EU-SA2019-008.pdf>

847 <https://www.zerodayinitiative.com/advisories/ZDI-19-988/>

848 https://googleprojectzero.blogspot.com/2017/04/over-air-exploiting-broadcoms-wi-fi_4.html

849 https://github.com/Matheus-Garbelini/sweyntooth_bluetooth_low_energy_attacks

850 cve-2017-0561,6957,6975

851 search the advisory list at <https://xenbits.xen.org/xsa/> for “netback”/“netfront”/“pcnet”

852 <https://arxiv.org/abs/2208.09975>

853 https://www.blackhat.com/docs/us-17/wednesday/us-17-Vanhoeft-WiFuzz-Detecting-And-Exploiting_Logical-Flaws-In-The-Wi-Fi-Cryptographic-Handshake-wp.pdf

854

855 Where is the manufacturer the best place to mitigate the risks? Those should be the ones the manufacturer treats,

856 otherwise they are documented for the integrator.

857 Don’t ship with undocumented interfaces!!!

858 Problems with protocols working as designed are not in scope.

859 Problems with the implementation of the protocols by the interface are in scope.

860 Potential sources:

861 https://owasp.org/owasp-istg/03_test_cases/physical_interfaces/index.html

862 <https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/IT-Sicherheitskennzeichen/Informationen-Kategorie-Mobile-Endgeraete/Informationen-Kategorie-Mobile-Endgeraete.html>

863

864 https://portal.etsi.org/webapp/workprogram/Report_WorkItem.asp?WKI_ID=69549

865 What about shipping a whole linux?

866 Is there a use case where we care about glitching of the network interface itself? think about it

867

- 868 • Disable all interfaces that intercept incoming packets above data link layer and do not pass them to the to the
- 869 host
- 870 • Check that outgoing packets only contain the data requested to be copied from host
- 871 • Don’t auto-connect to a network that is not really the same network

872 C.3 Assumptions

873 List assumptions that are relevant to the risk analysis for these threats. Everything is

874 hackable if you try hard enough. What kinds of threats are in and out of scope?

875 What are you assuming is the sophistication of attack? Relate to use cases.

876 FIXME more assumptions, associate with risk factors and security requirements

877 Assume no physical tampering

878 For wireless - operating environment of standard applies

879 C.4 Risk assessments of threats

880 For each threat identified above, use likelihood and magnitude of the threat to
881 assess its risk in the context of use cases. The results should be consistent with the
882 mapping of use cases to security profiles.

883 Guidance from latest PT1 draft:

884 An analysis in terms of likelihood and magnitude of a product's threats is required
885 to be able to determine the product's risks.

886 NOTE 1 This document does not require a specific methodology for a cybersecurity
887 risk analysis as long as the cybersecurity risk estimation is based on the likelihood
888 of occurrence and magnitude of loss or disruption of cybersecurity risks. Thus,
889 different approaches and models such as the fishbone model, event tree analysis or
890 fault tree models can be used within the analysis of cybersecurity risks.

891 NOTE 2 A qualitative estimation of the cybersecurity risks can be performed using
892 risk matrices that map qualitative categories of the likelihood of occurrence and
893 qualitative categories of magnitude of loss or disruption to cybersecurity risk
894 categories.

895 NOTE 3 A quantitative estimation of the cybersecurity risks can be performed using
896 scoring systems that map qualitative categories of the likelihood of occurrence and
897 qualitative categories of magnitude of loss or disruption to certain values.

898 FIXME pick methodology

Annex D (informative): Risk evaluation guidance

FIXME random notes below, should be rewritten or deleted when no longer necessary

Attack vectors that are the responsibility of the network interface:

- Arbitrary packets from outside the system
- OS-validated packets from unprivileged users inside the system
- Any unprivileged user-accessible device driver API

Out of scope attack vectors:

- Anything the OS is responsible for
 - Firmware updates
 - Direct bit twiddling of registers

Refer to normative standards:

- Device driver attack vectors
- Physical interface specific attack vectors?

D.1 Mapping of risks to requirements

Table mapping the identified risks to requirements

D.2 Risks not treated by the requirements

If any risks are not treated by the normative requirements, describe non-normative suggestions to mitigate them.

D.3 Risk acceptance criteria

Describe how to decide if residual risks are tolerable.

D.4 Residual risks

Describe how to treat any residual risks, for example by documenting them or informing the user.

Annex L (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

DRAFT ANNEX L - DO NOT CONSIDER THE CONTENT

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

NOTE: The above paragraphs have to be repeated in the Foreword.

The annex shall have a table for a clear indication of correspondence between normative clauses of the standard and the legal requirements aimed to be covered.

It should be evaluated - on the basis of the legal requirements supported and other information given in a harmonised standard - how detailed correspondence can be indicated between the normative elements of the harmonised standard and the legal requirements aimed to be covered. However, where this correspondence is expressed in too general terms, it could lead to a situation where the Commission cannot assess whether the Harmonised Standard satisfies the requirements, which it aims to cover, and subsequently publication of its references in the OJEU according to Article 10(6) of the Regulation is significantly delayed or is not possible at all.

EXAMPLE for a table:

Table: Table A.1: Relationship between the present document and the requirements of EU Regulation 2024/2847

Harmonised Standard ETSI EN 304 6xx

Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	Use case	Condition
1					
2					
3					
...					

949	Key to columns:
950	Requirement:
951	No A unique identifier for one row of the table which may be used to identify a requirement.
952	Description A textual reference to the requirement.
953	Requirements of Regulation Identification of article(s) defining the requirement in the Regulation.
954	Clause(s) of the present document Identification of clause(s) defining the requirement in the present document unless
955	another document is referenced explicitly.
956	Requirement Conditionality:
957	Use case Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's
958	claimed functionality of the equipment (C).
959	Condition Explains the conditions when the requirement is or is not applicable for a requirement which is classified
960	"conditional".
961	NOTE 1: The table cannot indicate direct relationship between the relevant legal
962	requirement and other standards or normative clauses contained in other standards.
963	NOTE 2: The order of the first and the second columns can be changed.
964	NOTE 3: The title of this column can be adapted on the basis of specific needs
965	The annex shall have at least the following two warnings.
966	A warning stating that presumption of conformity is effective only as long as the reference is maintained in the OJEU
967	by the Commission. The following URL-address https://ec.europa.eu/growth/single-market/european-
968	standards/harmonised-standards_en to consult the latest list of Harmonised Standards published in the OJEU should be
969	provided.
970	Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list
971	published in the Official Journal of the European Union. Users of the present document should consult frequently the
972	latest list published in the Official Journal of the European Union.
973	A warning stating that those products or services which are within the scope of a relevant standard may be also subject
974	to other Union legislation.
975	Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

976

Annex <L+3> (informative): Bibliography

977

<Publication>: “<Title>”.<Edition>. <Year>, <Issue designation>, <Page location>.

978

Annex <L+4> (informative): Change history

979

The “Change history/Change request (history)” annex shall be included in every revised or amended harmonised standard and shall contain information concerning significant changes that have been introduced by it. It shall be presented as a table.

980

981

Date	Version	Information about changes
<Month year>	<#>	<Changes made are listed in this cell>

982

History

983

The following table will automatically be filled in by the ETSI Secretariat.

Document History		
Version	Date	Milestone
	<#>	

984